

PROJECT REPORT 2

Web Application Penetration Testing Using OWASP Top 10 Framework

Prepared By

Md Washim Baksh

Domain

Cybersecurity | Web Application Security | Penetration Testing

Duration

4 Weeks

Abstract

Web applications are among the most frequently targeted assets by cyber attackers due to their exposure to the internet and access to sensitive data. The objective of this project was to conduct a structured penetration test on a vulnerable web application using the OWASP Top 10 framework to identify, exploit, and assess common web security vulnerabilities.

A controlled testing environment was established using OWASP Juice Shop and DVWA (Damn Vulnerable Web Application). Security testing was performed using Burp Suite and manual testing techniques to identify vulnerabilities including SQL Injection, Cross-Site Scripting (XSS), Broken Authentication, Sensitive Data Exposure, Security Misconfiguration, and Broken Access Control.

The identified vulnerabilities were analyzed for business impact, documented with proof-of-concept demonstrations, and accompanied by remediation recommendations to improve the application's overall security posture.

1. Introduction

Web applications play a critical role in modern business operations by providing services to customers, employees, and stakeholders. However, insecure web applications can expose organizations to significant risks such as data breaches, unauthorized access, and service disruption.

The Open Web Application Security Project (OWASP) publishes the OWASP Top 10, a widely recognized list of the most critical web application security risks. This project applies the OWASP Top 10 methodology to evaluate a vulnerable web application and demonstrate real-world web security testing techniques.

2. Project Objectives

The primary objectives of this project were:

- Understand the OWASP Top 10 security risks.
 - Set up a vulnerable web application testing environment.
 - Perform web application reconnaissance.
 - Identify common web application vulnerabilities.
 - Exploit vulnerabilities in a controlled environment.
 - Document Proof-of-Concept (PoC) findings.
 - Assess business impact and risk severity.
 - Recommend remediation strategies.
-

3. Lab Environment Setup

Virtualization Platform

- VirtualBox / VMware Workstation

Testing Machine

- Kali Linux

Vulnerable Applications

- DVWA (Damn Vulnerable Web Application)
- OWASP Juice Shop

Security Testing Tools

- Burp Suite Community Edition
 - Firefox Browser
 - OWASP ZAP (Optional)
 - SQLMap (Verification)
 - Developer Tools
-

4. Tools Used

Tool	Purpose
Kali Linux	Penetration Testing Platform
Burp Suite	Interception and Web Testing
DVWA	Vulnerable Web Application
OWASP Juice Shop	Security Testing Environment
SQLMap	SQL Injection Verification
Firefox Browser	Application Interaction
OWASP Top 10	Security Assessment Framework

5. Methodology

The penetration testing methodology followed the industry-standard web application assessment process:

Phase 1: Reconnaissance

- Application mapping
- Page discovery
- Parameter identification
- Session analysis

Phase 2: Vulnerability Identification

- Manual testing
- Automated testing
- Input validation testing
- Authentication testing

Phase 3: Exploitation

- Verification of vulnerabilities
- Controlled exploitation
- Impact assessment

Phase 4: Reporting

- Documentation of findings
 - Proof-of-Concept creation
 - Remediation recommendations
-

6. Week-wise Implementation

Week 1: OWASP Top 10 Study and Environment Setup

Activities Performed

- Studied OWASP Top 10 vulnerabilities.
- Installed DVWA.
- Installed OWASP Juice Shop.
- Configured Kali Linux testing environment.
- Installed and configured Burp Suite.
- Performed application reconnaissance.
- Conducted spidering and content discovery.

Reconnaissance Activities

Using Burp Suite:

- Intercepted HTTP requests.
- Mapped application structure.
- Identified user input fields.
- Analyzed cookies and sessions.

Outcome

Successfully prepared a testing environment and identified application attack surfaces.

Week 2: Testing Critical Web Vulnerabilities

1. SQL Injection (Injection)

Description

SQL Injection occurs when user input is improperly validated and is directly included in SQL queries.

Testing Method

- Identified login and search fields.
- Injected SQL payloads.
- Observed application responses.

Impact

- Unauthorized database access.
- Data extraction.
- Authentication bypass.

Risk Level

Critical

2. Broken Authentication

Description

Weak authentication mechanisms may allow attackers to compromise user accounts.

Testing Method

- Tested weak passwords.
- Analyzed session handling.
- Evaluated login functionality.

Impact

- Unauthorized access.
- Account takeover.
- Privilege escalation.

Risk Level

High

3. Cross-Site Scripting (XSS)

Description

XSS vulnerabilities allow attackers to inject malicious scripts into web pages.

Testing Method

- Tested reflected input fields.
- Injected JavaScript payloads.
- Verified script execution.

Impact

- Session hijacking.
- Credential theft.
- Client-side attacks.

Risk Level

High

4. Sensitive Data Exposure

Description

Sensitive information may be exposed due to improper protection mechanisms.

Testing Method

- Inspected HTTP responses.
- Examined cookies.
- Reviewed application configuration.

Impact

- Information disclosure.
- Data breach.
- Regulatory violations.

Risk Level

High

Week 3: Advanced Security Assessment

5. Security Misconfiguration

Description

Improper configuration settings can introduce security weaknesses.

Findings

- Default configurations.
- Excessive error messages.
- Unnecessary services enabled.

Impact

- Increased attack surface.
- Information leakage.

Risk Level

Medium

6. Broken Access Control

Description

Improper authorization mechanisms allow users to access restricted resources.

Testing Method

- Forced browsing.

- Parameter manipulation.
- Privilege escalation testing.

Impact

- Unauthorized data access.
- Administrative function abuse.

Risk Level

Critical

7. Proof of Concept (PoC) Documentation

Finding 1: SQL Injection

Vulnerability

SQL Injection in Login Form

Proof of Concept

- Access login page.
- Enter crafted SQL payload.
- Observe authentication bypass.

Result

Successfully bypassed authentication controls.

Severity

Critical

Finding 2: Cross-Site Scripting (XSS)

Vulnerability

Reflected XSS

Proof of Concept

- Locate vulnerable input field.
- Inject JavaScript payload.
- Observe script execution.

Result

Client-side script successfully executed.

Severity

High

Finding 3: Broken Access Control

Vulnerability

Unauthorized Access to Administrative Resources

Proof of Concept

- Login as low-privileged user.
- Modify resource identifiers.
- Access restricted functionality.

Result

Unauthorized access successfully achieved.

Severity

Critical

8. Risk Assessment

Vulnerability	Severity	Business Impact
SQL Injection	Critical	Database Compromise
Broken Access Control	Critical	Unauthorized Access
Broken Authentication	High	Account Takeover
XSS	High	Session Hijacking
Sensitive Data Exposure	High	Data Leakage
Security Misconfiguration	Medium	Information Disclosure

9. Security Recommendations

SQL Injection

- Use parameterized queries.

- Implement prepared statements.
- Validate user input.

Broken Authentication

- Enforce strong password policies.
- Implement Multi-Factor Authentication (MFA).
- Secure session management.

Cross-Site Scripting

- Input validation.
- Output encoding.
- Content Security Policy (CSP).

Sensitive Data Exposure

- Encrypt sensitive information.
- Enforce HTTPS.
- Secure cookie settings.

Security Misconfiguration

- Remove unnecessary services.
- Disable debug mode.
- Harden server configurations.

Broken Access Control

- Implement Role-Based Access Control (RBAC).
- Conduct authorization checks.
- Apply least privilege principles.

10. Key Outcomes

The project successfully demonstrated practical web application penetration testing techniques based on the OWASP Top 10 framework.

Major achievements include:

- Successful deployment of vulnerable web applications.
- Hands-on experience with Burp Suite.
- Identification and validation of critical web vulnerabilities.
- Development of Proof-of-Concept attack demonstrations.
- Risk analysis and vulnerability prioritization.
- Preparation of professional security assessment documentation.

11. Skills Gained

Technical Skills

- Web Application Penetration Testing
- OWASP Top 10 Security Testing
- Burp Suite
- Vulnerability Assessment
- SQL Injection Testing
- Cross-Site Scripting Testing
- Authentication Security Testing
- Access Control Testing

Professional Skills

- Security Documentation
 - Report Writing
 - Risk Assessment
 - Analytical Thinking
 - Problem Solving
 - Technical Communication
-

12. Conclusion

This project provided practical experience in identifying, exploiting, and mitigating web application vulnerabilities using the OWASP Top 10 framework. Through the use of DVWA, OWASP Juice Shop, and Burp Suite, critical security flaws were successfully identified and analyzed.

The assessment highlighted the importance of secure coding practices, proper authentication mechanisms, access control enforcement, and security configuration management. The project strengthened practical skills required for roles such as SOC Analyst, Web Application Security Analyst, VAPT Consultant, and Penetration Tester.

References

1. OWASP Top 10 Security Risks
2. OWASP Juice Shop Documentation
3. DVWA Documentation

4. Burp Suite Documentation
 5. OWASP Testing Guide
 6. OWASP Web Security Testing Methodology
 7. PortSwigger Web Security Academy
-